

PUBLIC PROFESSIONAL BRIEF

Detection Engineering Brief

Sigma-style detection design for MFA push fatigue and OT scheduled-task behavior, with logging requirements and triage workflow.

Prepared by	Bernard Boakye Appiah
Scenario organization	NorthGrid Energy - fictional Ontario critical infrastructure operator
Document type	Detection engineering brief
Public disclosure	All content is sanitized and based on a fictional security assessment scenario.
Date	July 2026

Selected assessment metrics

2 Detection cases	Windows + Entra ID Primary logs	T1053.005 / T1621 ATT&CK mapping
----------------------	------------------------------------	-------------------------------------

Public disclosure note: NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

Purpose and Executive Summary

This brief presents the detection engineering portion of the NorthGrid Energy assessment. It focuses on two practical detection themes: OT scheduled-task behavior associated with Industroyer2-style activity and MFA push fatigue patterns in Microsoft Entra ID sign-in logs.

The main professional lesson is that writing a detection rule is only one part of detection engineering. A useful rule also requires the right logs, a realistic false-positive review, enrichment fields, triage logic, and a response process that fits operational technology safety constraints.

SCOPE

Detection Scope

Detection case	Log source needed	Technique mapping	Operational value
OT scheduled task creation	Windows Security logs from EMS/SCADA hosts, especially Event ID 4698.	MITRE ATT&CK T1053.005 - Scheduled Task/Job: Scheduled Task.	Identifies suspicious task creation before possible OT-impacting execution.
MFA push fatigue	Microsoft Entra ID SigninLogs and AADNonInteractiveUserSignInLogs.	MITRE ATT&CK T1621 - Multi-Factor Authentication Request Generation.	Detects repeated push failures that may indicate social engineering or credential misuse.

SIGMA LOGIC

OT Scheduled Task Detection

The Industroyer2-related logic focuses on scheduled task creation using Windows Security Event ID 4698 and OT-related naming or task content. The rule was improved by requiring both OT-related task naming and suspicious task content, then filtering known legitimate GE service paths and accounts where validated.

```
detection:
  selection_event:
    EventID: 4698
  selection_taskname:
    TaskName|contains:
      - 'IEC-104'
      - 'sc_data'
      - 'WindowsScheduler'
  selection_suspicious_content:
    TaskContent|contains:
      - 'powershell'
      - 'cmd.exe'
      - 'wscript'
      - 'schtasks'
      - '.bat'
      - '.ps1'
      - 'Temp'
      - 'AppData'
  condition: selection_event and selection_taskname and selection_suspicious_content
```

Field or logic	Purpose	Triage value
EventID 4698	Targets Windows scheduled task creation.	Shows when a new task is registered, before or around execution.
TaskName contains OT terms	Finds tasks using names tied to IEC-104 or SCADA-related patterns.	Raises relevance on EMS/SCADA hosts.

Field or logic	Purpose	Triage value
TaskContent contains script tools	Looks for PowerShell, cmd, script interpreters, temp paths, or scheduled task utilities.	Separates suspicious automation from normal enterprise tasks.
Legitimate GE filter	Suppresses known vendor paths and service accounts after validation.	Reduces false positives without hiding unknown suspicious tasks.
High severity	Prioritizes a match on an OT host.	Prompts OT-aware response instead of ordinary workstation triage.

IDENTITY DETECTION

MFA Push Fatigue Detection

The MFA fatigue rule identifies repeated MFA push failures for the same user in a short time window. This pattern can represent a user being pressured to approve authentication attempts or an attacker repeatedly triggering prompts after obtaining a password.

```
title: Microsoft Entra ID MFA Push Fatigue Detection
logsource:
  product: azure
  service: signinlogs
detection:
  selection:
    ResultType:
      - 50074
      - 50076
    ClientAppUsed|contains: 'Microsoft Authenticator App'
  timeframe: 10m
  condition: selection | count(UserPrincipalName) by UserPrincipalName > 5
level: high
```

Detection element	Purpose	Why it matters
ResultType 50074 / 50076	Selects MFA-related sign-in failure states.	Focuses on failed or challenged authentication activity.
ClientAppUsed contains Authenticator	Narrows activity to push-style authenticator flows.	Matches the social engineering pattern of push fatigue.
Count by user over 10 minutes	Finds repeated attempts against one account.	Detects bursty push bombing behavior.
High severity	Directs SOC attention quickly.	A successful approval after repeated failures can signal compromise.

QUALITY REVIEW

False Positive Review and Evasion Considerations

Case	How it can appear	Analyst action
User changed phone or authenticator app	Repeated failures after device migration or app reinstall.	Contact the user through a trusted channel; compare device, IP, location, and application to baseline.
Mobile connectivity issue	Push notifications time out or arrive late.	Verify location and failure type; check for successful login from a trusted device.
Low-and-slow attacker	Attacker keeps attempts below threshold over a longer period.	Add a longer-window rule, such as more than 10 denials in 60 minutes, and correlate by source IP or ASN.
Spraying across users	Attempts distributed across multiple accounts.	Create an aggregate rule for one source attempting MFA against several users.

OPERATIONS

SOC Triage and Response Flow

For both rules, the output must feed a practical triage process. The key enrichment fields are timestamp, user, source IP, device, application, host, task name, task content, parent process, and whether the host belongs to IT or OT.

- 1 Validate the alert context: asset criticality, user role, host type, and whether the activity is expected.
- 2 Enrich with recent authentication, endpoint, network, and change-management records.
- 3 For MFA fatigue, contact the user through a trusted channel and revoke sessions if compromise is suspected.
- 4 For OT scheduled task alerts, escalate to OT security before isolating hosts so safety and monitoring requirements are preserved.
- 5 Document outcome as true positive, benign authorized change, false positive, or tuning candidate.

REQUIREMENTS

Detection Coverage Gaps

Gap	Risk	Required improvement
EMS/SCADA Windows logs not ingested	Scheduled task rule cannot fire if Event ID 4698 is not collected.	Forward Windows Security logs from EMS/SCADA servers to the SIEM.
Entra sign-in logs not ingested	MFA fatigue rule lacks required fields such as UserPrincipalName and ResultType.	Enable Microsoft Entra ID connector and ingest SigninLogs.
No OT asset context	SOC may treat an EMS alert like a normal endpoint.	Tag OT assets in the SIEM and route alerts to OT-aware responders.
No tested response playbook	Alert may generate noise without decisive containment.	Create playbooks for identity compromise and suspicious OT task creation.

RECOMMENDATIONS

Recommendations

- 1 Ingest Windows Security logs from EMS and SCADA-supporting servers, including scheduled task creation events.
- 2 Ingest Microsoft Entra ID sign-in logs and deploy MFA fatigue analytics with both short-window and low-and-slow variants.
- 3 Create known-good filters only after validating legitimate vendor paths, task names, and service accounts.
- 4 Map detections to MITRE ATT&CK and attach response playbooks so alerts lead to consistent action.
- 5 Add OT safety review to containment actions so detection does not create preventable operational disruption.